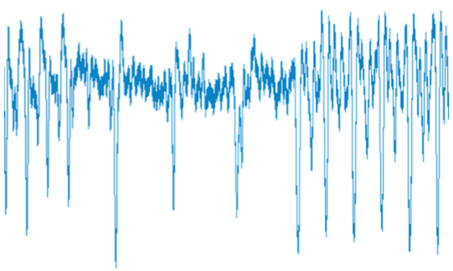
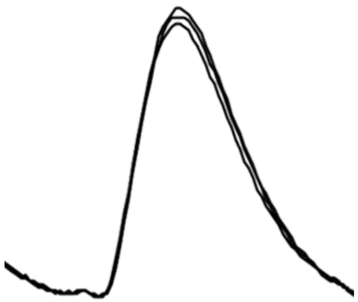
Code:

Side-channel attacks 1

David Oswald





Goals of this lecture

After this lecture, you will …

- Know some types of side-channel attacks
- Understand how such attacks can break secure crypto and other algorithms
- Know some countermeasures
- Be prepared to follow the next lectures with more complex attacks

Principle of Side-Channel Analysis
(here: listen to **Sound**)

A Bank Robbery

Principle of Side-Channel Analysis

The world is changing…

Principle of Side-Channel Analysis
(now: measure the power consumption / run-time)

The world is changing…

…the tools are, too.

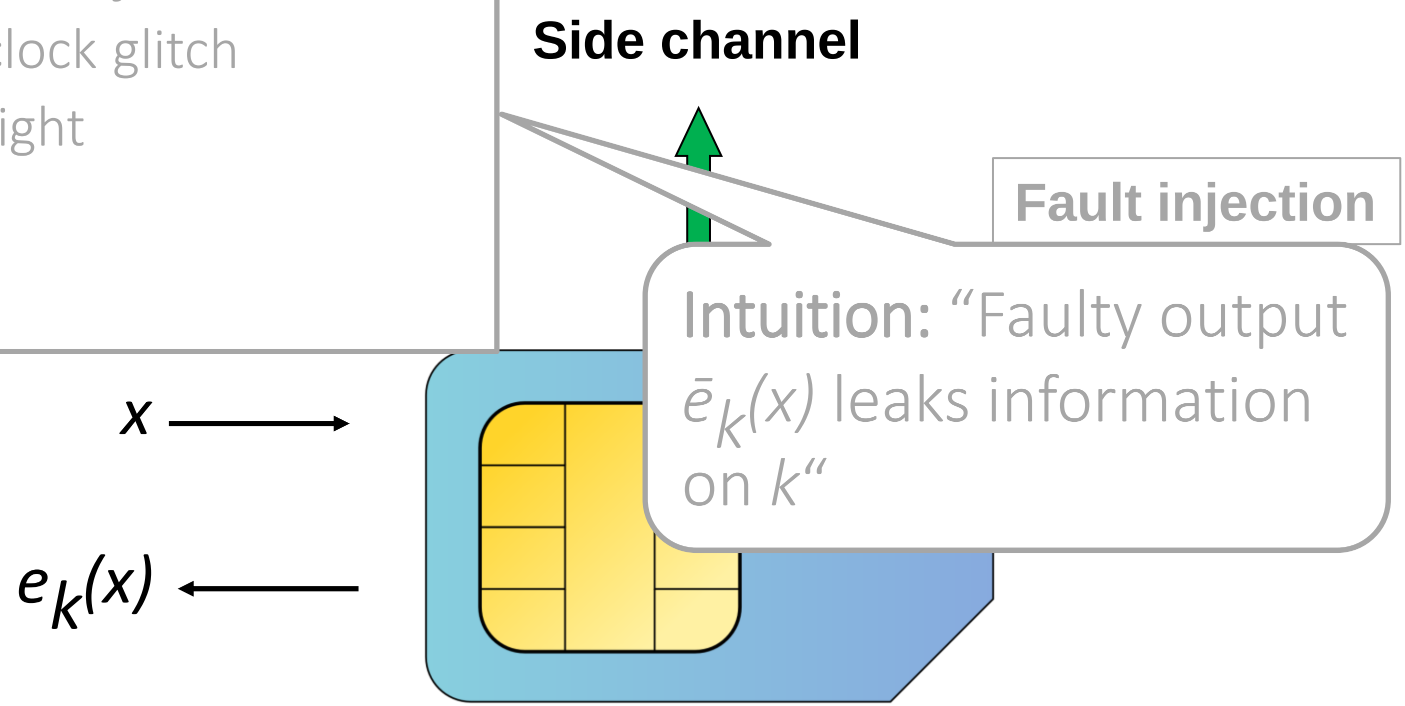
Embedded reality:

Adversa

controls

2. Control: fault injection

- Power/clock glitch
- (Laser) light
- ...

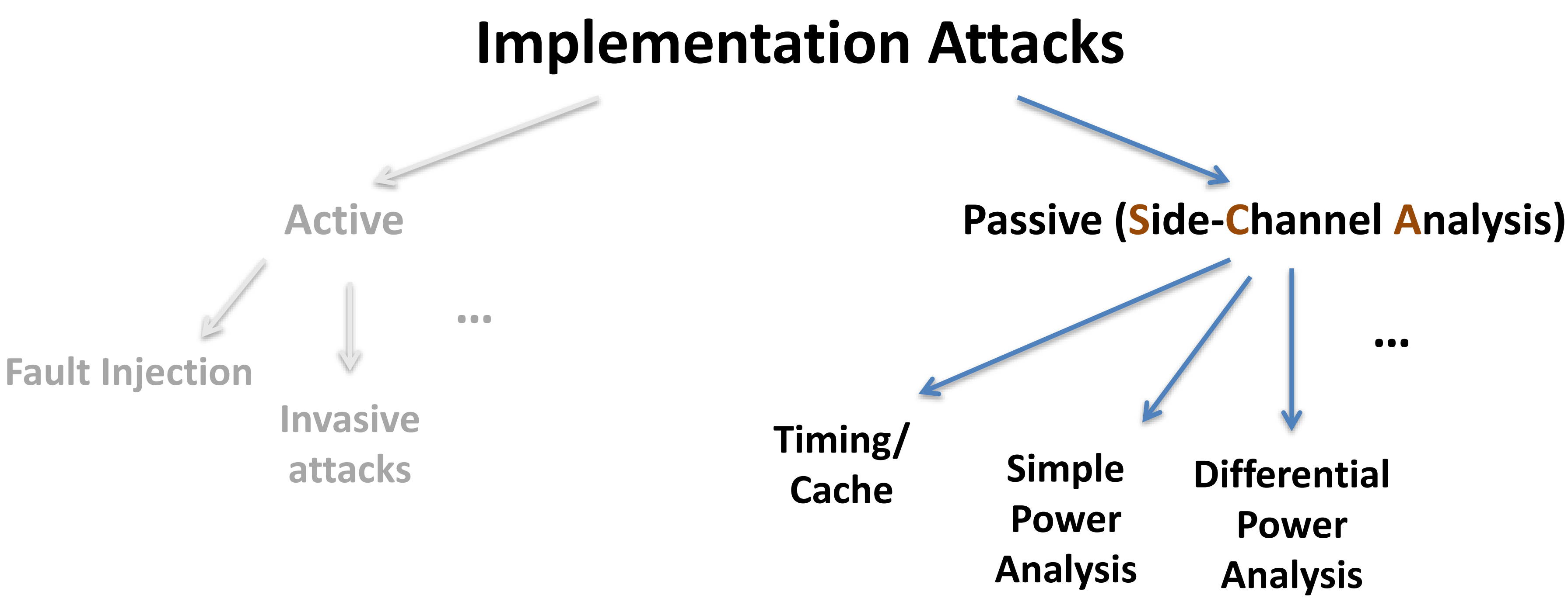


Intuition: “Faulty output $\bar{e}_k(x)$ leaks information on k“

1. Observe: side channel

- Power consumption
- EM emanation
- (Cache) timing
- ...

Classification of Implementation Attacks



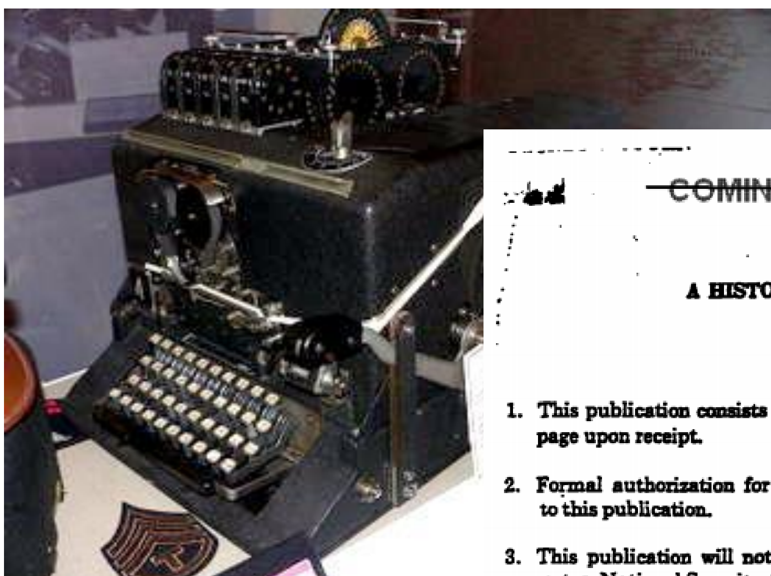
Implementation attacks are independent of mathematical security and work for any cipher

Implementation attacks: a short history

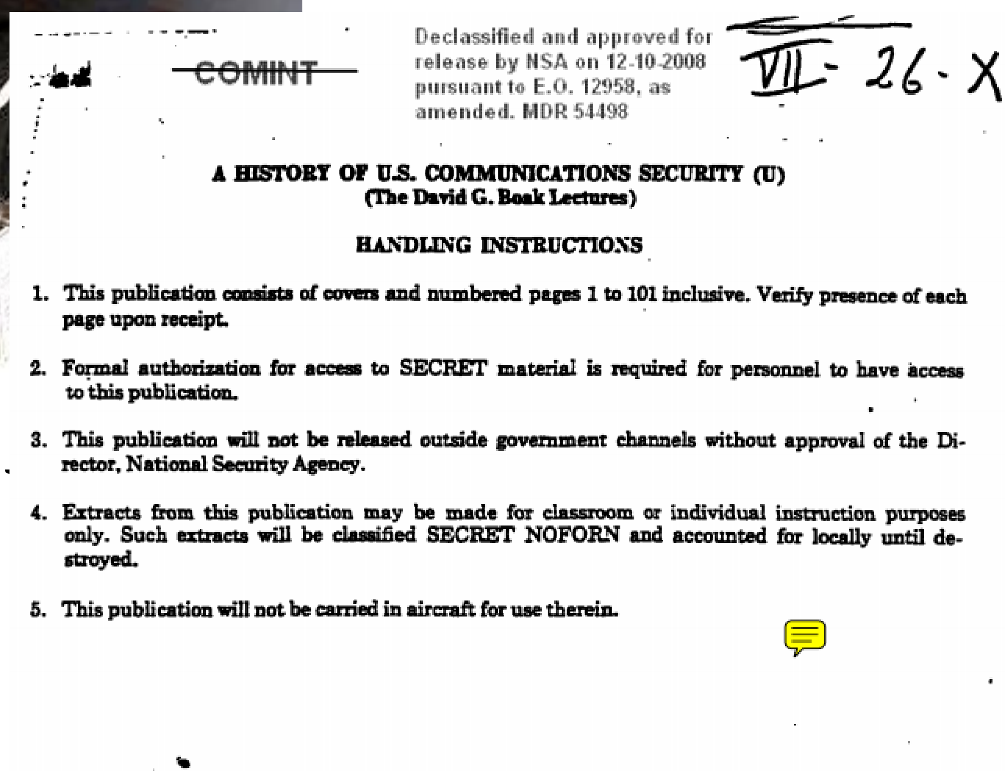
- Known for many decades (e.g. TEMPEST)
- Poor understanding prior to 1996
  (at least outside intelligence agencies)
- End 1990s: „golden era“
  - Fault attacks (RSA CRT), 1996
  - Timing attacks, 1996
  - SPA, DPA, 1998
- Since 1999: hundreds of research papers

Implementation attacks: a short history

- Known for many decades (e.g. TEMPEST)
- Poor understanding prior to 1996
  (at least outside intelligence agencies)



en era“



~~COMINT~~

Declassified and approved for release by NSA on 12-10-2008 pursuant to E.O. 12958, as amended. MDR 54498

VII - 26 · X

A HISTORY OF U.S. COMMUNICATIONS SECURITY (U)
(The David G. Boak Lectures)

HANDLING INSTRUCTIONS

1. This publication consists of covers and numbered pages 1 to 101 inclusive. Verify presence of each page upon receipt.
2. Formal authorization for access to SECRET material is required for personnel to have access to this publication.
3. This publication will not be released outside government channels without approval of the Director, National Security Agency.
4. Extracts from this publication may be made for classroom or individual instruction purposes only. Such extracts will be classified SECRET NOFORN and accounted for locally until destroyed.
5. This publication will not be carried in aircraft for use therein.

papers

Possible Side Channels

- General goal: Recover secrets (keys and more)
- **Runtime** (timing attacks) 

A timing attack on PIN checks

```
bool check_pin(int pin_entered[4]) ≈ memcmp()
{
  for(int i = 0; i < 4; i++) {
    if(pin_stored[i] != pin_entered[i]) {
      return false;
    }
  }
  return true;
}
```

Recovering the PIN

Entered PIN	Runtime (µs)
0000	134
1000	133
2000	166
3000	129
4000	133
5000	132
6000	134
7000	128
8000	136
9000	129

Recovering the PIN

Entered PIN	Runtime (μs)
0000	134
1000	133
2000	**166**
3000	129
4000	133
5000	132
6000	134
7000	128
8000	136
9000	129

Recovering the PIN

Entered PIN	Runtime (μs)
2000	165
2100	160
2200	166
2300	163
2400	199
2500	159
2600	158
2700	167
2800	166
2900	165

Recovering the PIN

Entered PIN	Runtime (μs)
2000	165
2100	160
2200	166
2300	163
2400	**199**
2500	159
2600	158
2700	167
2800	166
2900	165

Recovering the PIN

Entered PIN	Runtime (µs)
2400	198
2410	201
2420	197
2430	197
2440	198
2450	199
2460	228
2470	195
2480	204
2490	197

Recovering the PIN

Entered PIN	Runtime (µs)
2400	198
2410	201
2420	197
2430	197
2440	198
2450	199
2460	**228**
2470	195
2480	204
2490	197

Recovering the PIN

Entered PIN	Result
2460	false
2461	false
2462	false
2463	false
2464	false
2465	false
2466	false
2467	false
2468	true
2469	false

Recovering the PIN

Entered PIN	Result
2460	false
2461	false
2462	false
2463	false
2464	false
2465	false
2466	false
2467	false
2468	true
2469	false

Live-Demo

"Anything that can go wrong, will go wrong"

A simple timing attack

Preventing timing attacks

- There are more complex attacks than this example
  Typically the best countermeasure (for crypto):
  constant-time code, e.g. instead of:

  ```
  a = 0;
  if(x == 1)
      a = b;
  ```

  write

  ```
  a = b & (-x);
  ```

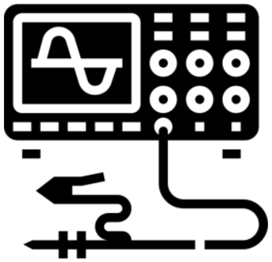
- Other approaches might work, but are less reliable / more specific - always check assembly!

A constant-time pin check

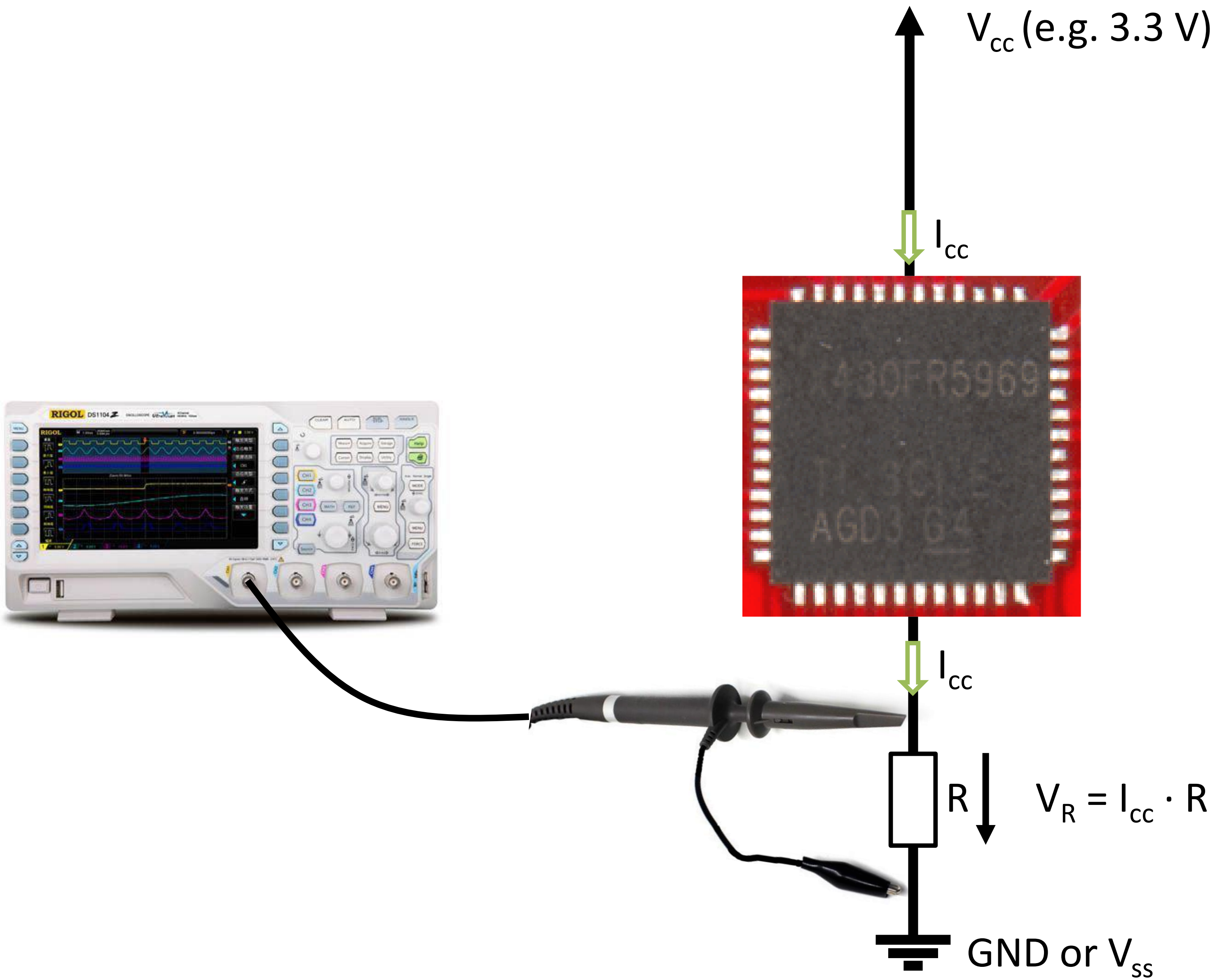
```
bool check_pin(int pin_entered[4])
{
  int mask = 0
  for(int i = 0; i < 4; i++) {
    mask |= pin_stored[i] ^ pin_entered[i];
  }
  return (mask == 0);
}
```

Possible Side Channels

- General goal: Recover secrets (keys and more)
- Runtime (timing attacks)
- Cache timing (more in a separate lecture)
- **Power analysis** – let's start with Simple Power Analysis (SPA)

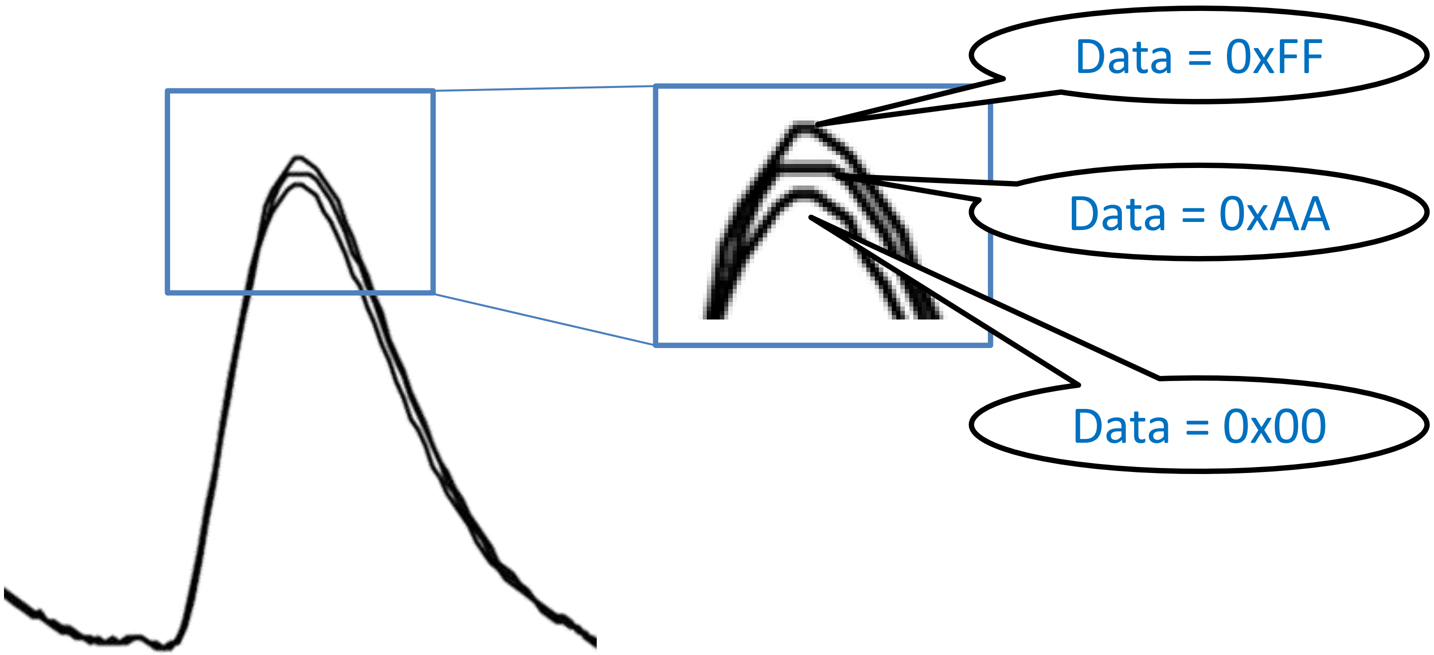


Measuring power consumption

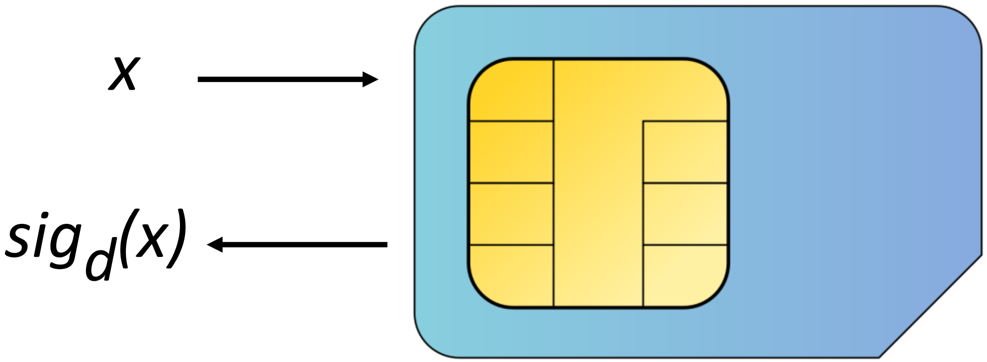


Side-channel analysis: leakage

Power consumption depends on the processed data



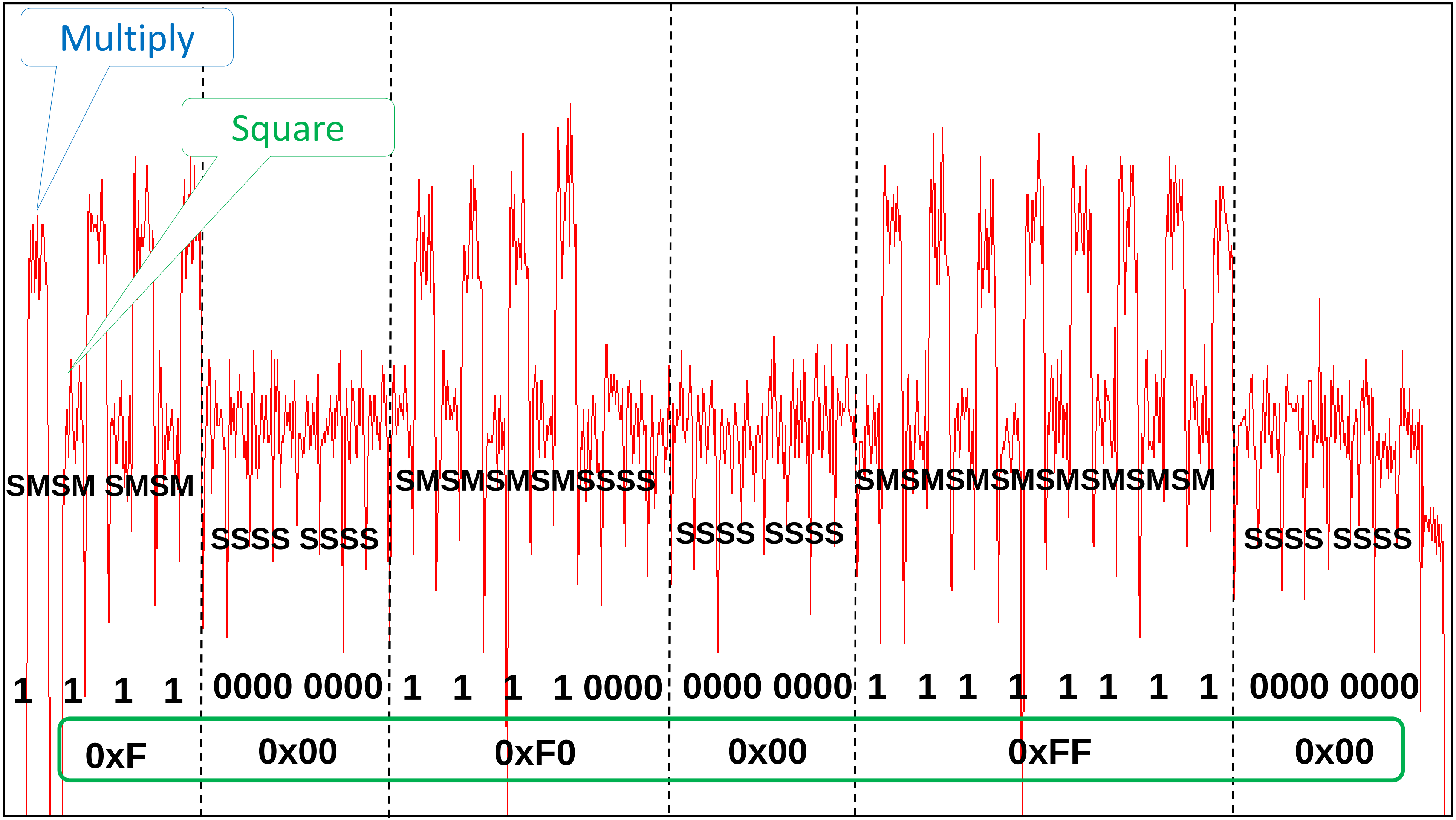
Example: RSA signature / decryption



Square-and-multiply

$y = x^d$ mod n: Left-to-right square-and-multiply:

```
y = 1
for i = 2048 – 1 … 0
   y = y² mod n
   if bit i of d == 1
      y = y * x mod n
   end if
end for
return y
```



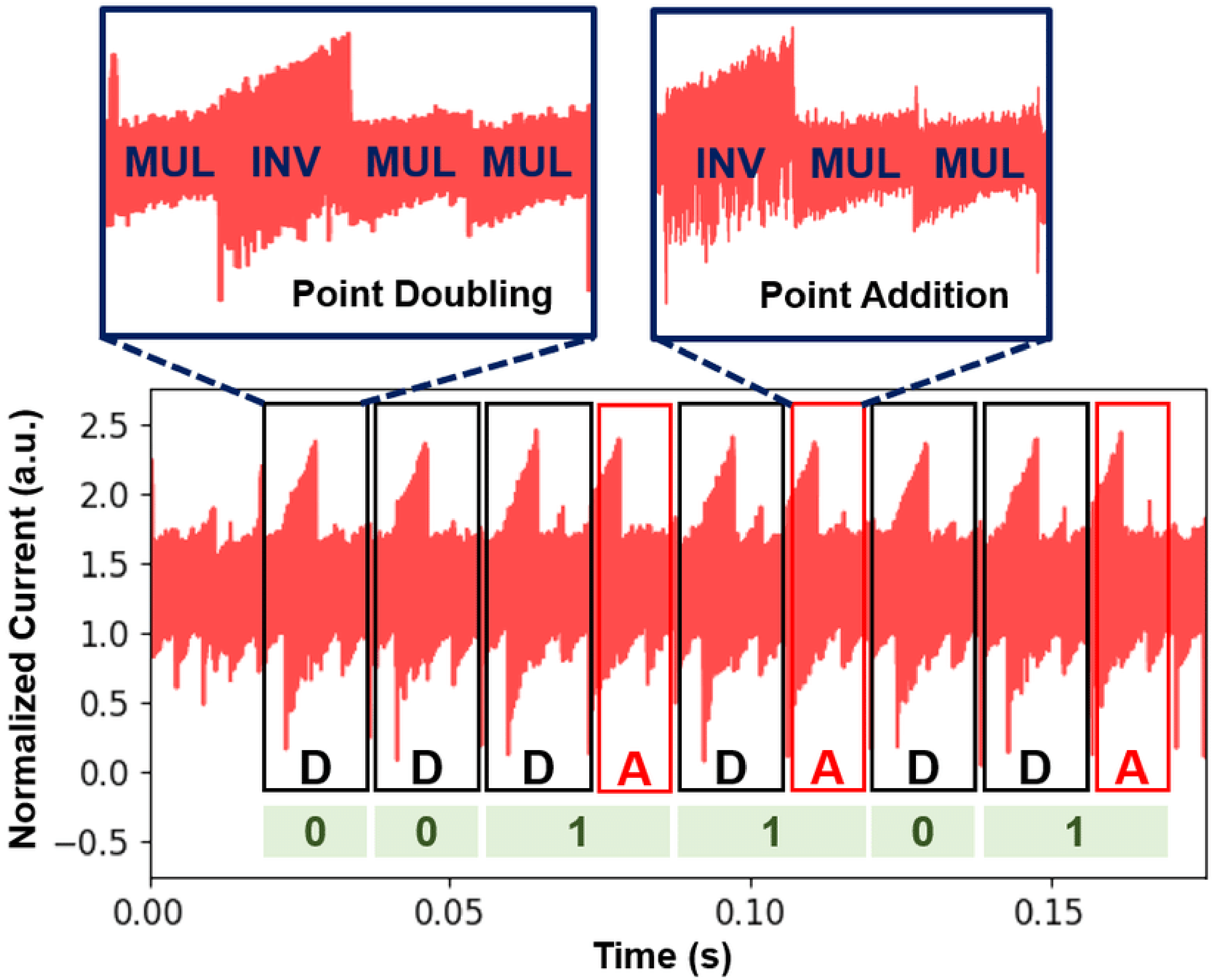
key value : 0xF 00 F0 00 FF 00

Double-and-add (for elliptic curves)

$Y = d \cdot X$: Left-to-right double-and-add:

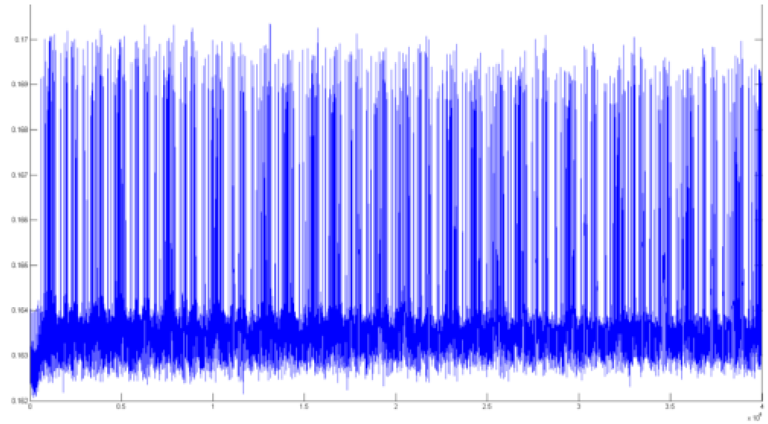
```
Y = id
for i = 256 − 1 … 0
   Y = 2·Y
   if bit i of d == 1
     Y = Y + X
   end if
end for
return Y
```

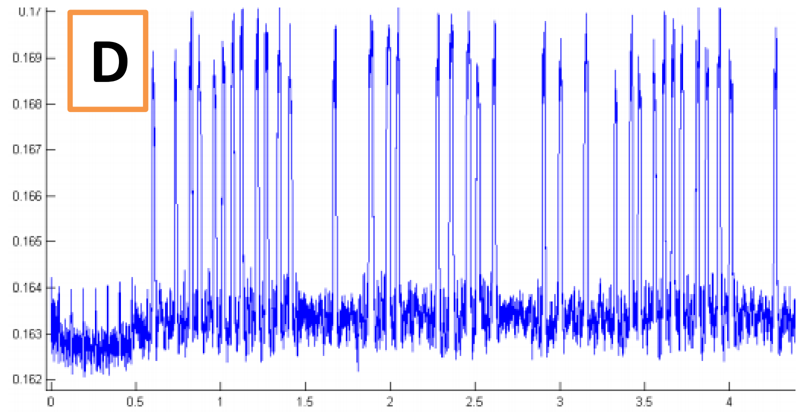
SPA on double-and-add

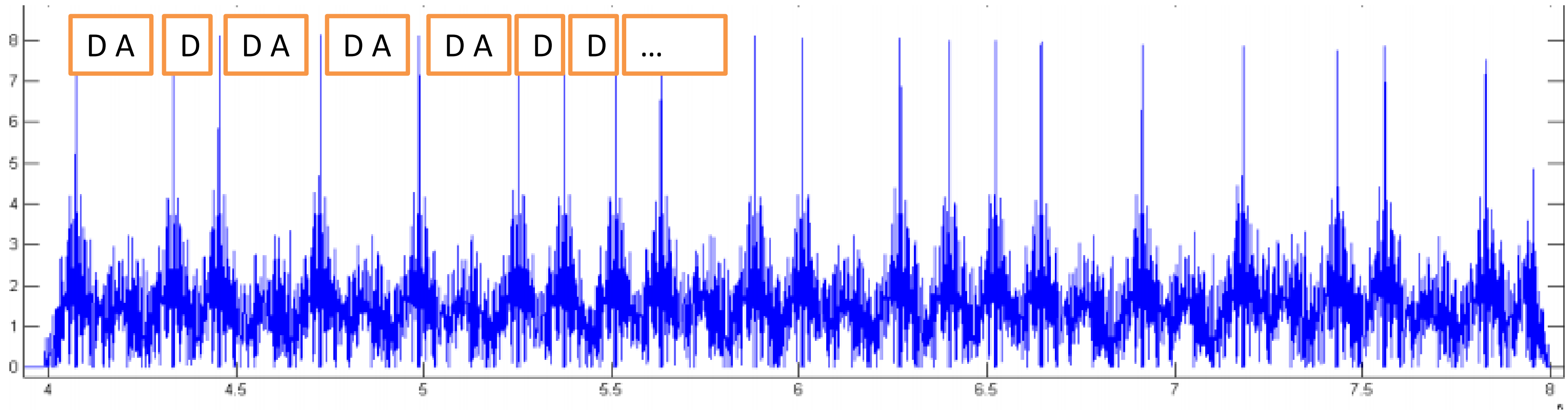


https://www.researchgate.net/publication/333358563_An_Energy-Efficient_Reconfigurable_DTLS_Cryptographic_Engine_for_Securing_Internet-of-Things_Applications

SPA on double-and-add







https://cosade.telecom-paristech.fr/presentations/s2_p2.pdf

Preventing SPA

- Add noise → can be filtered or averaged out
- Decrease signal / balance power consumption → requires special logic styles, costly
- Fix the algorithm:
  - Square-and-always-multiply
  - Double-and-always-add
  - Montgomery ladder
- Small leakages might still remain and go undetected

Other possible side channels (selection)

- Temperature 

Heat as a side channel

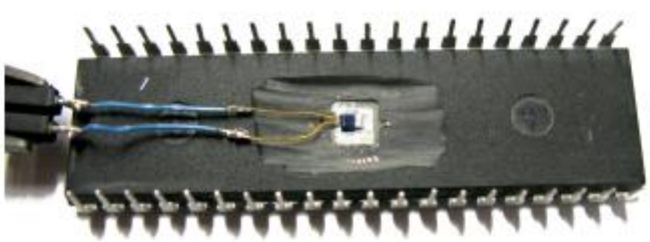
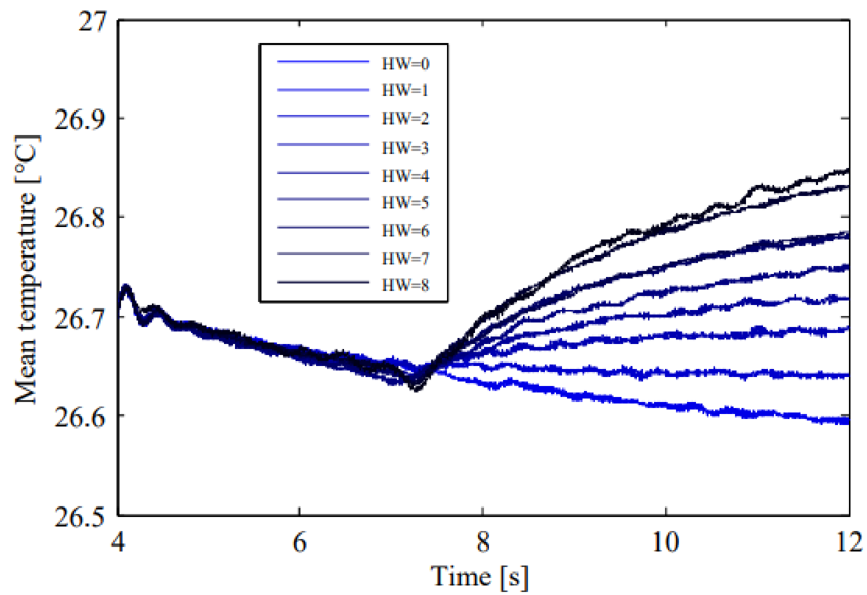


Fig. 2: Rear-side decapsulation of an ATmega162 to provide direct contact to the silicon substrate for the PT100.

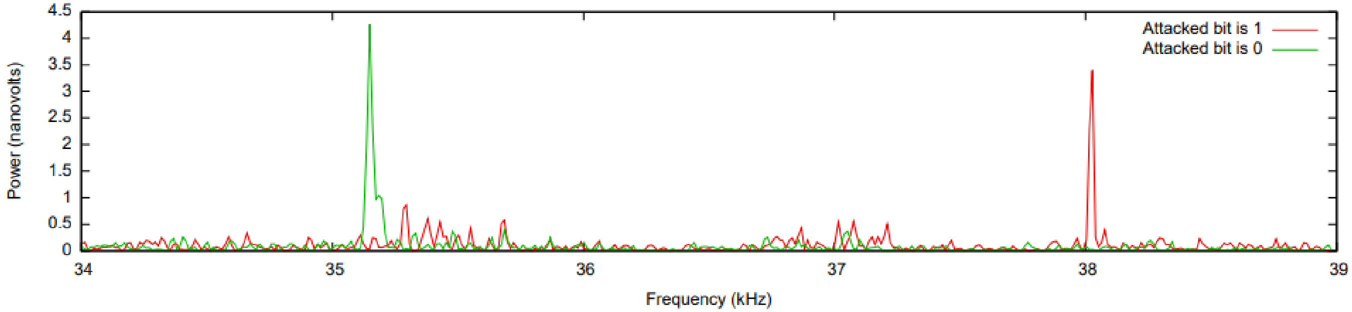
https://eprint.iacr.org/2014/190.pdf



Other possible side channels (selection)

- Temperature 
- Sound 

Acoustic side-channel attack on RSA



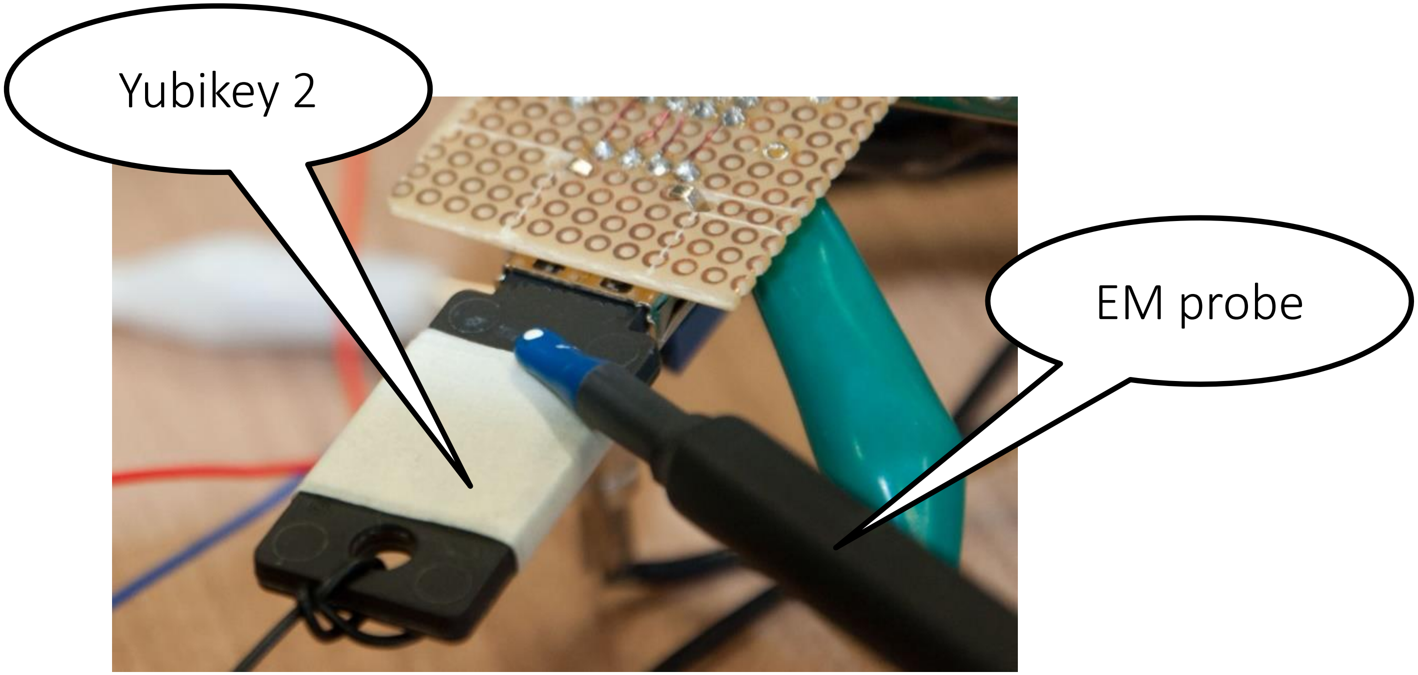
(c) Frequency spectra of the second modular exponentiation

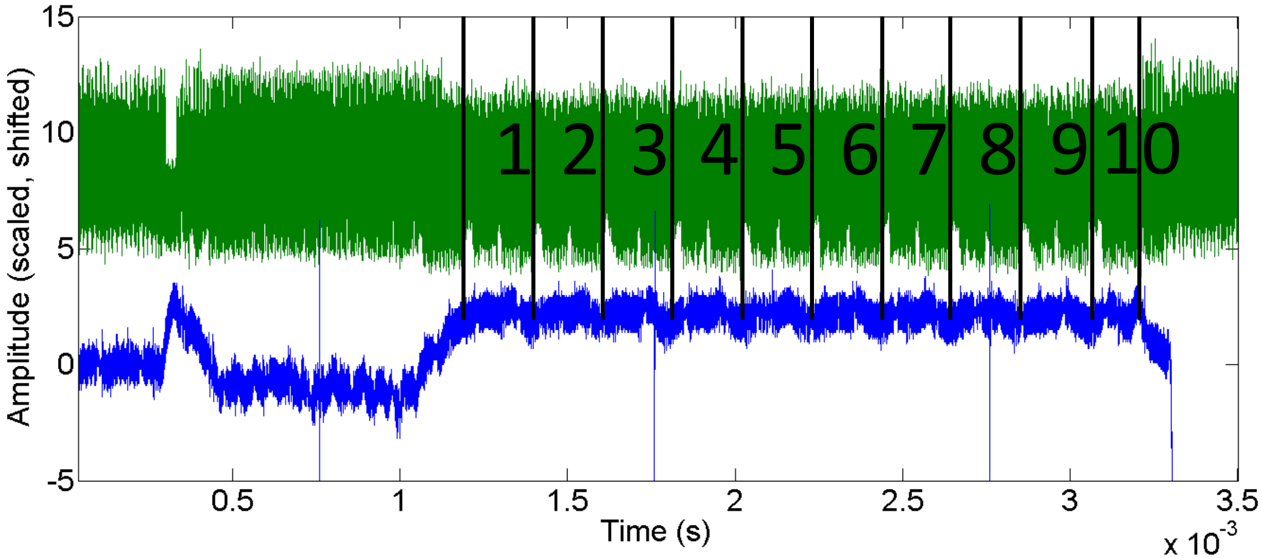
https://www.cs.tau.ac.il/~tromer/papers/acoustic-20131218.pdf

Other possible side channels (selection)

- Temperature 
- Sound 
- Electro-magnetic emanations 

EM side-channel attacks





Other possible side channels (selection)

- Temperature 
- Sound 
- Electro-magnetic emanations 
- Photonic emissions 

- …

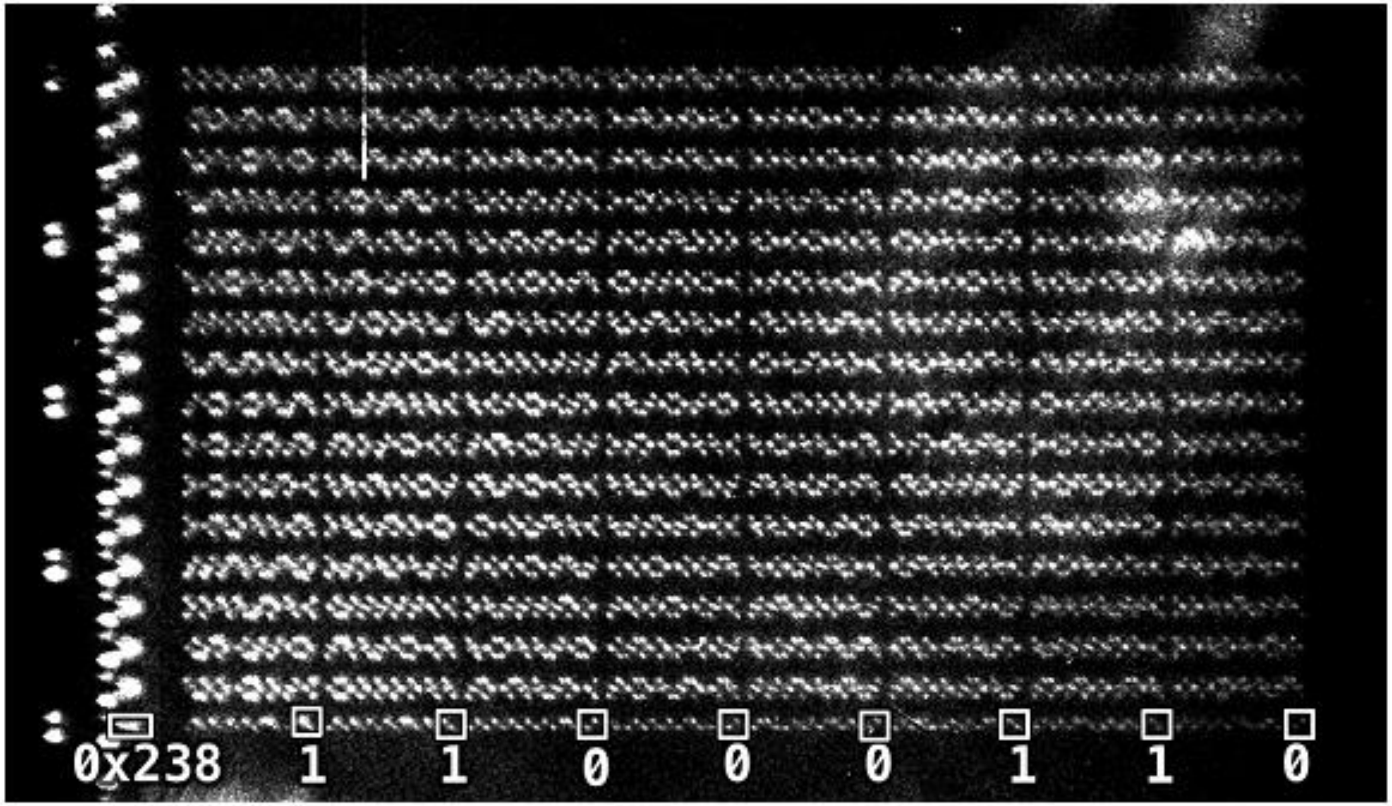


Fig. 3. Optical emission image of the S-Box in memory. The 256 bytes of the S-Box are located from 0x23F to 0x33E, see Table 3 in the appendix. The address 0x23F is the seventh byte of the 0x238 SRAM line, i.e. the S-Box has an offset of 7 bytes. The emissions of the row drivers are clearly visible to the left of the memory bank. The image allows direct readout of the bit-values of the stored data. The first byte for example, as shown in the overlay, corresponds to $01100011_2 = 63_{16}$, the first value of the AES S-Box.

http://www.iacr.org/archive/ches2012/74280037/74280037.pdf

Take-home points

- Side-channel attacks use *unintended* side effects
- Independent of the *mathematical security* of crypto and other algorithms
- Relevant for both small embedded devices (say smartcards) and large PC-grade CPUs
- Further reading: https://github.com/david-oswald/hwsec_lecture_notes
- **Next lecture(s):**
  - More advanced side-channel attacks on crypto algorithms
  - We'll break AES!

Thanks!

Questions / discussion?

d.f.oswald@bham.ac.uk